APRIL 2026

Professional Vulnerability Assessment Report

Security Analysis of Wikipedia

Report done by: **KIMBERLY FARAI MAGO**

NON-DISCLOSURE & LEGAL NOTICE

This report contains information obtained through a controlled and ethical security assessment of a public website. All findings are based on publicly accessible data and passive analysis techniques.
This report is for academic purposes only and does not represent a full security guarantee of the target system.

Executive Summary

This report presents a security assessment conducted on Wikipedia.org using passive and non-intrusive techniques. The objective was to evaluate the security posture of the website by identifying common weaknesses and analyzing configurations. Tools such as Nmap and OWASP ZAP were used alongside manual inspection.

The assessment identified two high-risk vulnerabilities, SQL Injection and Path Traversal, alongside several medium-risk misconfigurations, including missing security headers and cookie issues. The website demonstrates strong baseline security practices, including HTTPS enforcement and limited network exposure. Overall, targeted remediation is required to fully harden the application.

INTRODUCTION

A passive security assessment was conducted on Wikipedia.org to identify potential security weaknesses.
This assessment followed a non-intrusive approach, focusing on publicly accessible configurations. No exploitation or harmful actions were performed.

The goal was to simulate a real-world security audit from a consultant’s perspective.

SCOPE

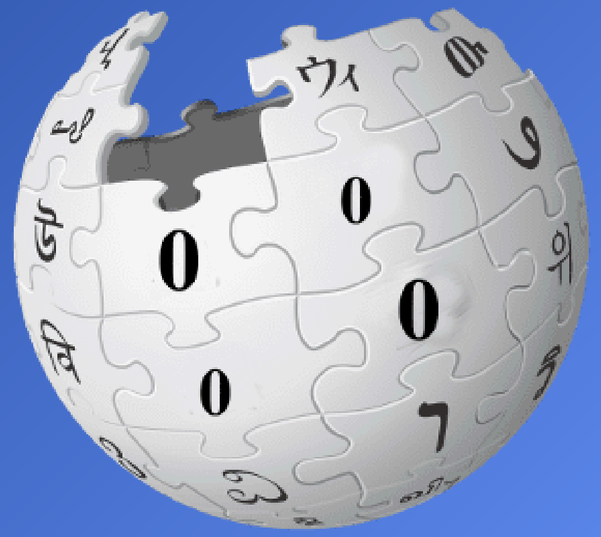
The assessment was limited to publicly accessible components of Wikipedia.org.

Scope included:

- HTTP/HTTPS services
- Web application responses
- Security headers
- Network exposure (open ports)

Out of Scope:

- Authentication systems
- Internal infrastructure
- Any form of exploitation or attack



WIKIPEDIA
The Free Encyclopedia

RISK RATING CLASSIFICATION

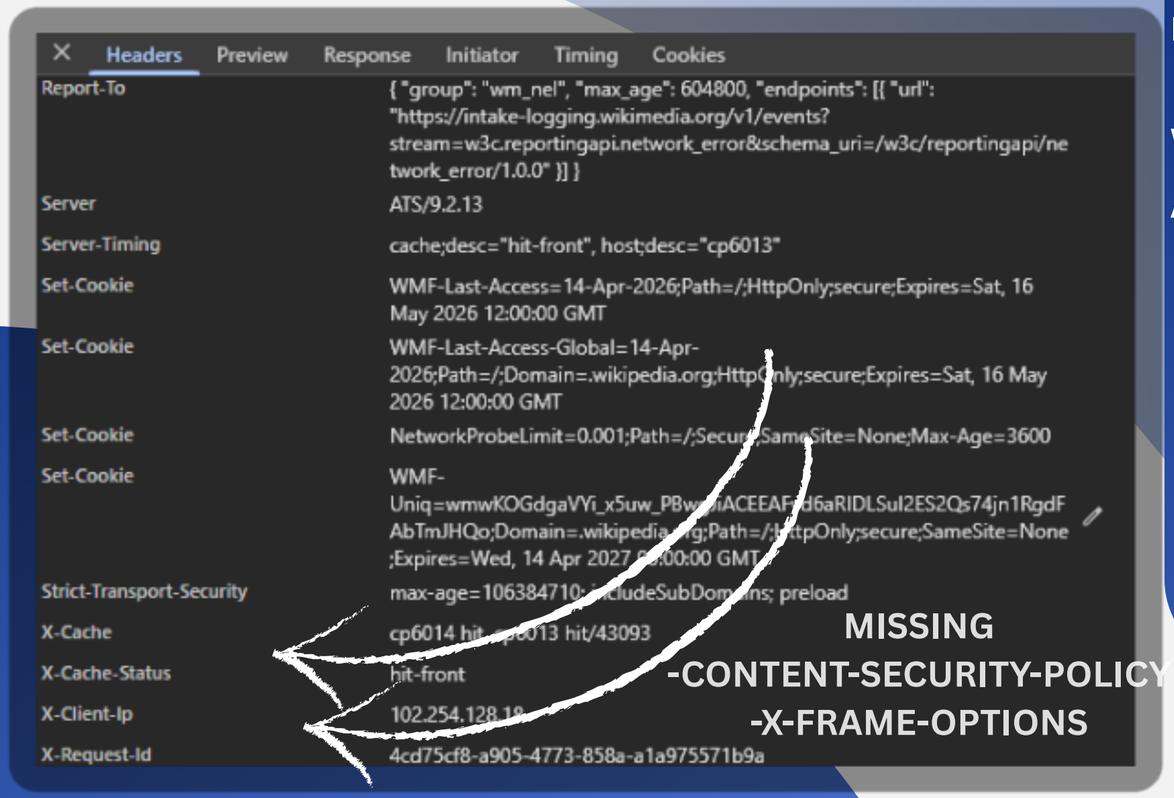
RISK	MEANING
HIGH	SERIOUS VULNERABILITY
MEDIUM	NEEDS ATTENTION
LOW	MINOR ISSUE
INFORMAL	NO RISK

VULNERABILITIES OVERVIEW

RISK LEVEL	COUNT
HIGH	2
MEDIUM	4
LOW	3
INFORMAL	1

VULNERABILITIES

VULNERABILITY 1



Headers | Preview | Response | Initiator | Timing | Cookies

Report-To	{ "group": "wm_nel", "max_age": 604800, "endpoints": [{ "url": "https://intake-logging.wikimedia.org/v1/events?stream=w3c.reportingapi.network_error&schema_uri=/w3c/reportingapi/network_error/1.0.0" }] }
Server	ATS/9.2.13
Server-Timing	cache;desc="hit-front", host;desc="cp6013"
Set-Cookie	WMF-Last-Access=14-Apr-2026;Path=/;HttpOnly;secure;Expires=Sat, 16 May 2026 12:00:00 GMT
Set-Cookie	WMF-Last-Access-Global=14-Apr-2026;Path=/;Domain=.wikipedia.org;HttpOnly;secure;Expires=Sat, 16 May 2026 12:00:00 GMT
Set-Cookie	NetworkProbeLimit=0.001;Path=/;Secure;SameSite=None;Max-Age=3600
Set-Cookie	WMF-Uniq=wmwKOGdgaVYi_x5uw_PBwqIACEEAFqd6aRIDLSuI2ES2Qs74jn1RgdFAbTmJHQo;Domain=.wikipedia.org;Path=/;HttpOnly;secure;SameSite=None;Expires=Wed, 14 Apr 2027 00:00:00 GMT
Strict-Transport-Security	max-age=106384710;includeSubDomains; preload
X-Cache	cp6014 hit, cp6013 hit/43093
X-Cache-Status	hit-front
X-Client-Ip	102.254.128.18
X-Request-Id	4cd75cf8-a905-4773-858a-a1a975571b9a

MISSING
-CONTENT-SECURITY-POLICY
-X-FRAME-OPTIONS

Name: Missing Security Headers
Risk Rating: Medium

Description:
Some recommended HTTP security headers were absent from Wikipedia's HTTP responses, including Content-Security-Policy and X-Frame-Options. Without these headers, the site is more susceptible to Cross-Site Scripting and Clickjacking attacks, where malicious scripts or deceptive frames could be used to manipulate users.

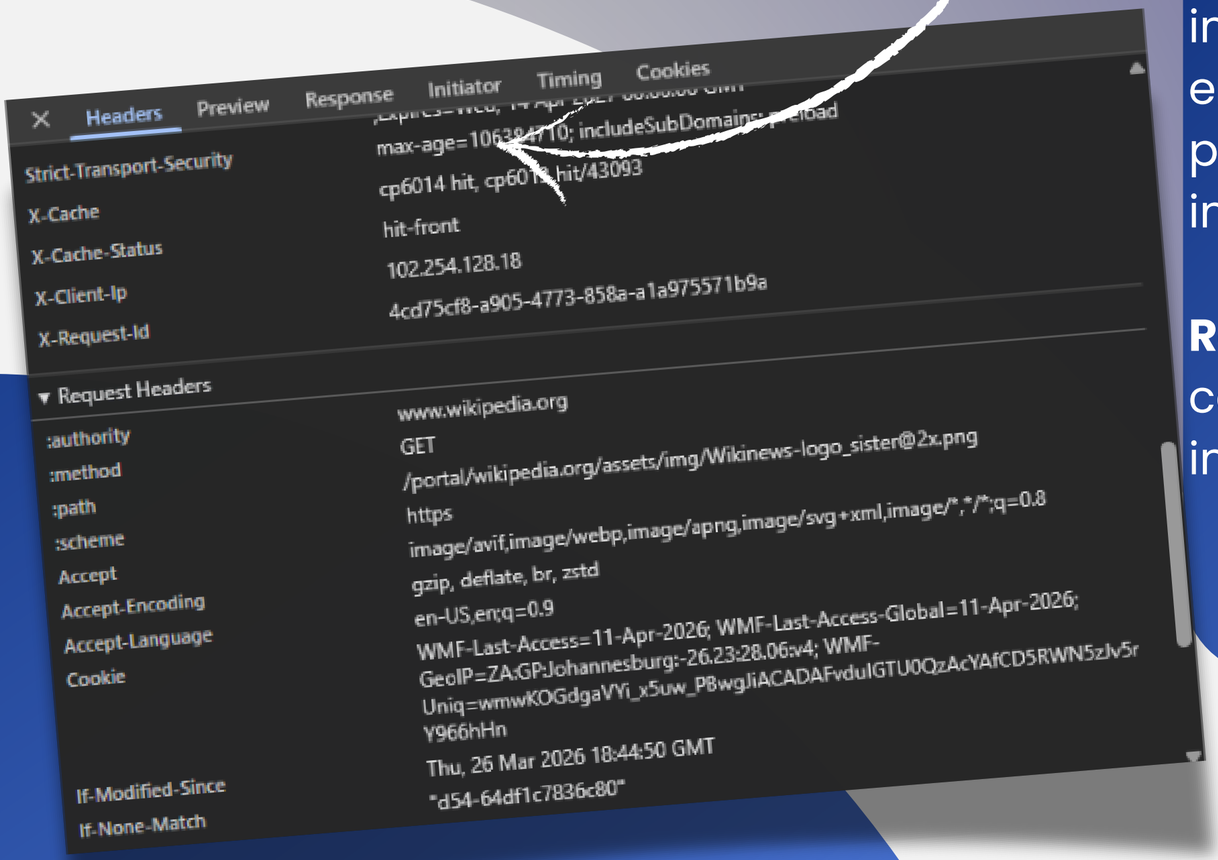
Target:
Wikipedia

Attack Techniques:
- Cross-Site Scripting (XSS)
- Clickjacking

Countermeasures:
- Implement CSP
- Add X-Frame-Options
- Add X-Content-Type-Options

VULNERABILITIES

VULNERABILITY 2

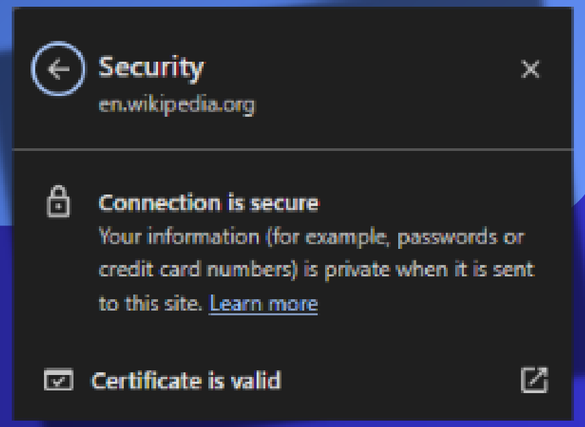


Name: HTTPS Enforcement (HSTS)

Risk Rating: Informational

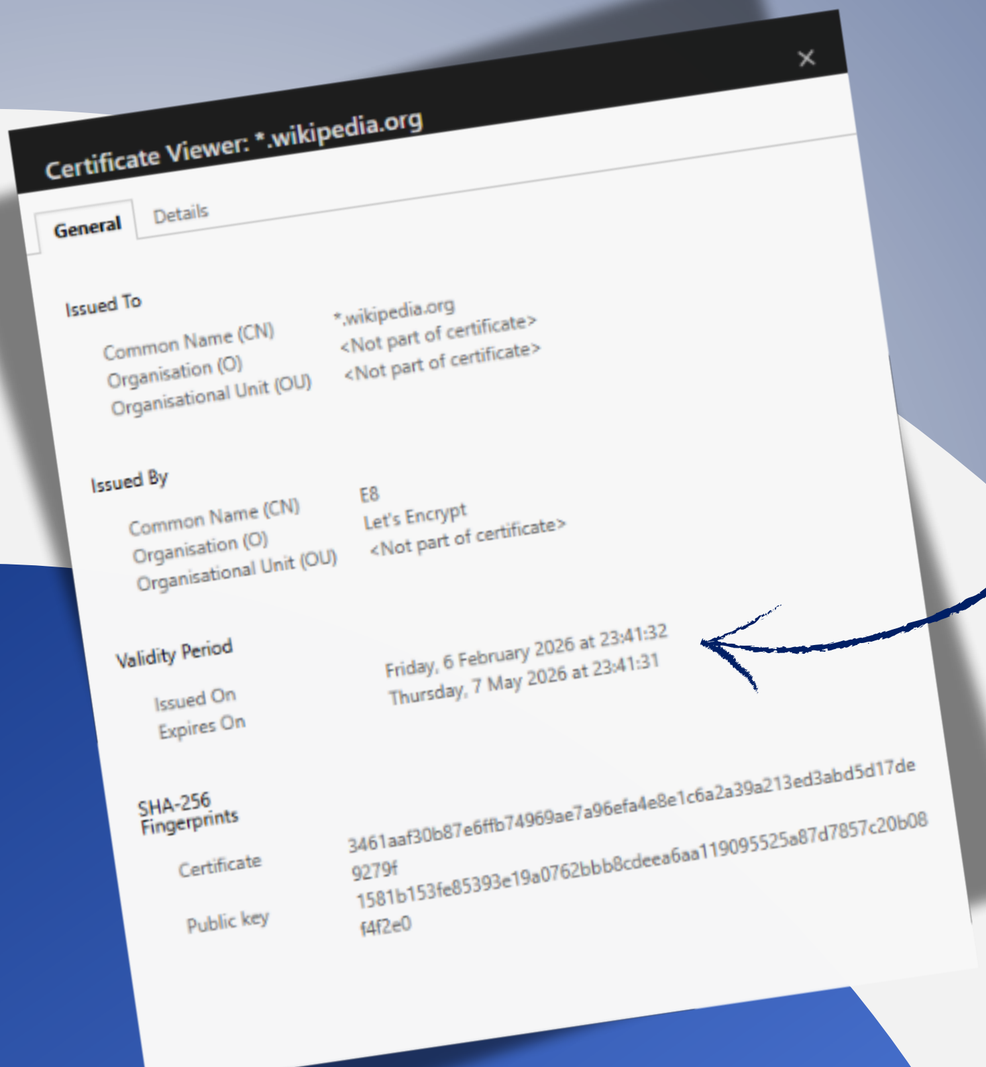
Full Description: Wikipedia enforces HTTPS across all pages using HTTP Strict Transport Security (HSTS). The Strict-Transport-Security header was confirmed with a max-age of 106,384,710 seconds (approximately 3 years), with includeSubDomains and preload directives active. This ensures browsers never connect over unencrypted HTTP, protecting users from downgrade attacks and traffic interception.

Remediation: No action required. Maintain the current HSTS configuration and ensure it is preserved during any future infrastructure changes.



VULNERABILITIES

VULNERABILITY 3



Name: SSL/TLS Certificate
Risk Rating: Low

Full Description: Wikipedia uses a valid SSL/TLS certificate issued by Let's Encrypt (E8). The certificate was issued on 6 February 2026 and expires on 7 May 2026, meaning it will expire in approximately 3 weeks. While encryption is currently active, failure to renew the certificate before expiry will cause browsers to display security warnings, potentially driving users away and breaking secure connections.

Remediation: Enable automatic certificate renewal through Let's Encrypt's auto-renew feature (certbot). Monitor expiry dates monthly.

VULNERABILITIES

VULNERABILITY 4

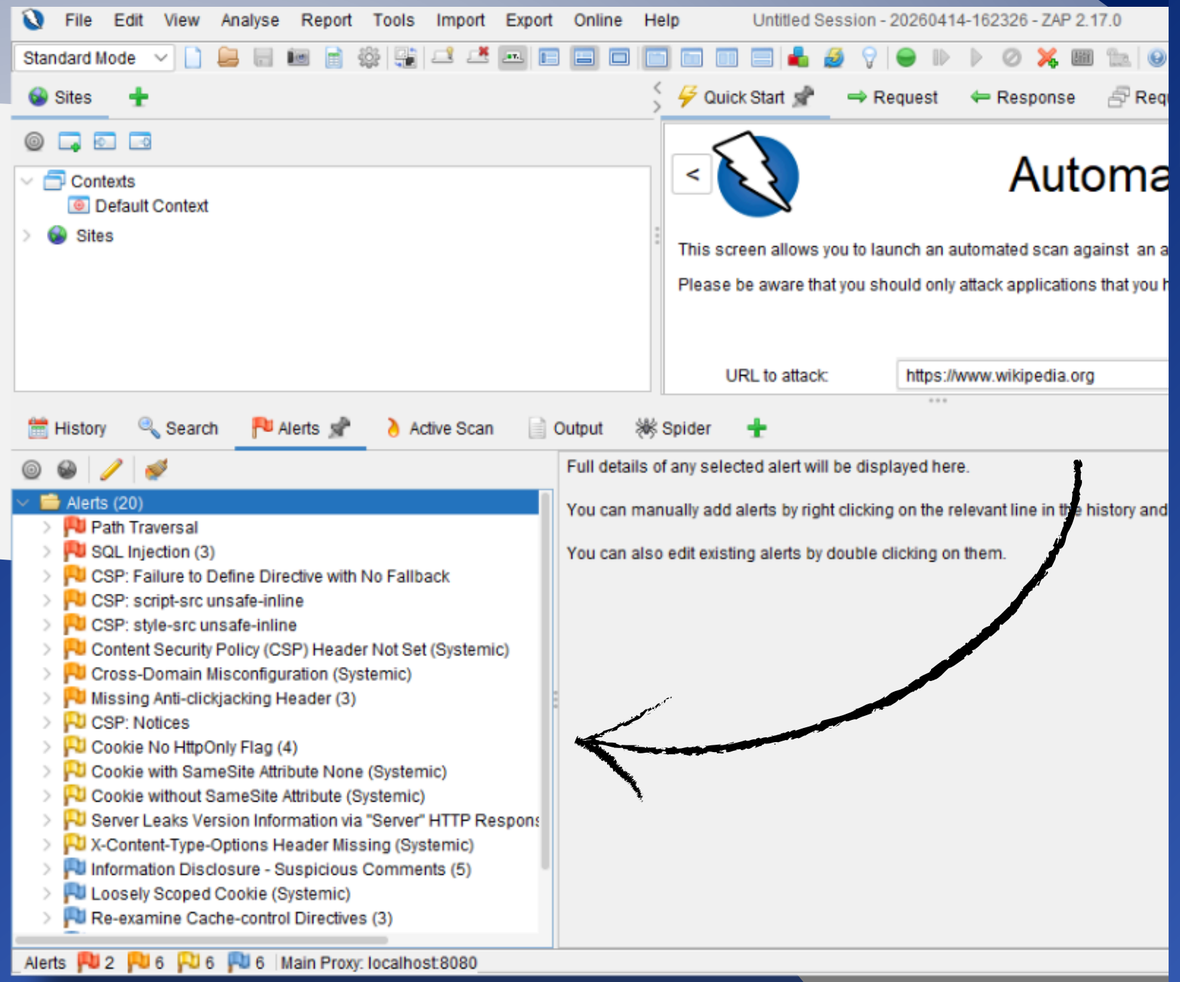
Name: Limited Open Ports (Nmap)
Risk Rating: Low

Full Description: An Nmap scan of Wikipedia.org revealed only ports 80 (HTTP) and 443 (HTTPS) are open. This is actually a positive security indicator, as unnecessary ports are closed, reducing the attack surface. However, port 80 still being open allows unencrypted HTTP traffic before redirection to HTTPS.

Remediation: Consider fully disabling port 80 and enforcing HTTPS-only access at the network level.

VULNERABILITIES

VULNERABILITY 5



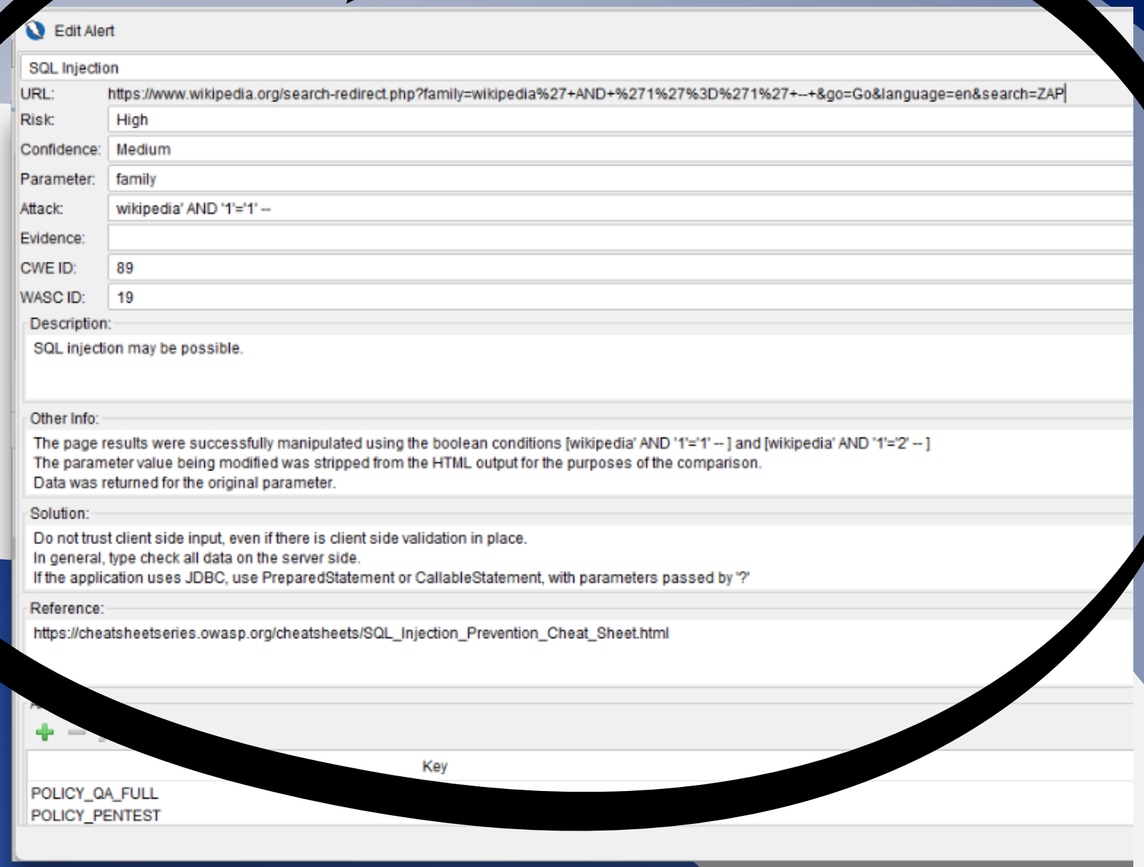
Name: OWASP ZAP Passive Scan
Risk Rating: Low

Description: A passive scan was conducted on Wikipedia.org using OWASP ZAP 2.17.0. The scan identified 20 alerts across multiple risk levels. No active exploitation was performed — all findings are based on observable application behaviour and HTTP response analysis. The scan revealed two high-risk vulnerabilities requiring immediate attention, alongside several medium-risk misconfigurations that collectively weaken the site's security posture.

Remediation: Address high-risk findings immediately. Review and resolve medium-risk findings in the next development cycle. Continue running passive scans after any major site update.

VULNERABILITIES

VULNERABILITY 5a



Name: OWASP ZAP Passive Scan (SQL Injection)
Risk Rating: High

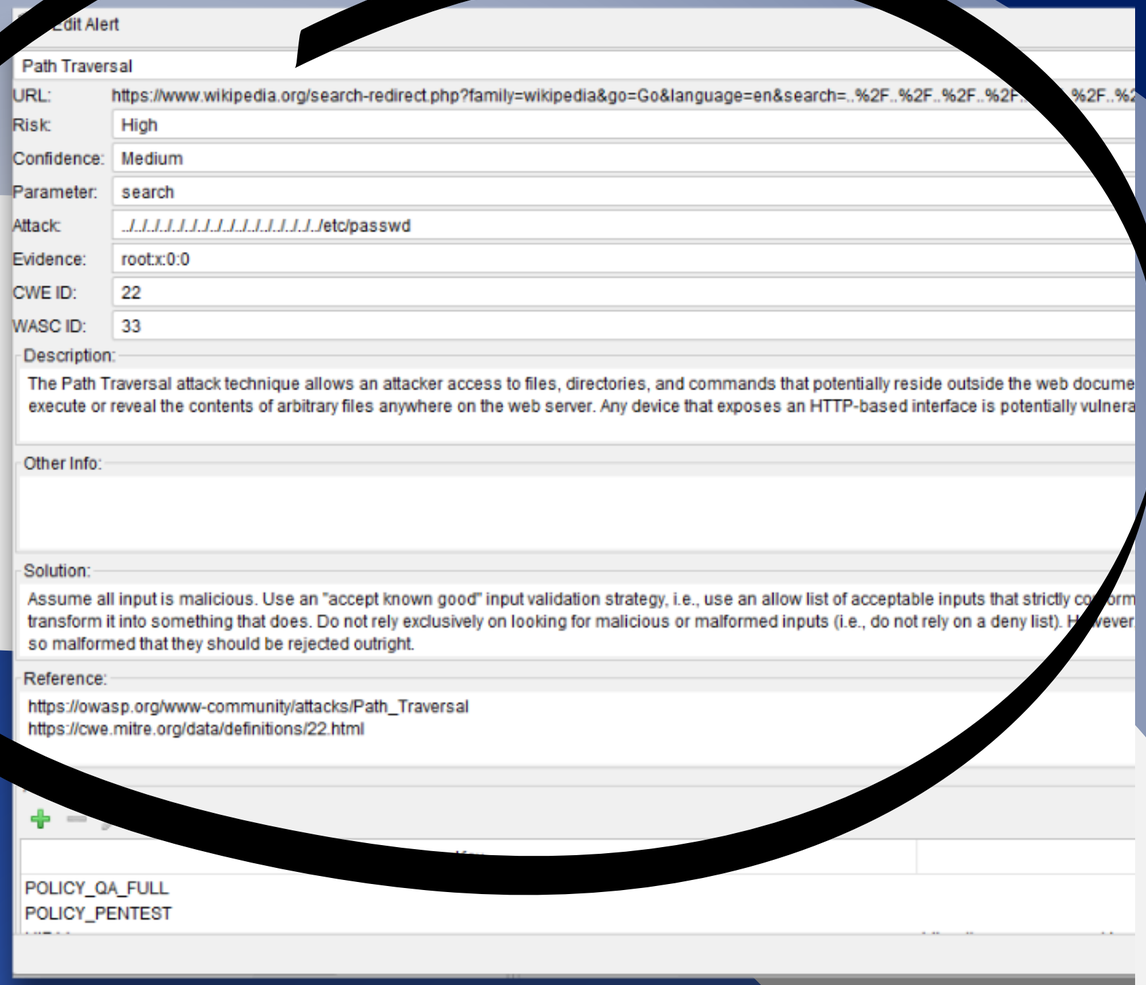
Description: ZAP successfully manipulated page results using SQL boolean conditions, confirming a potential SQL Injection point. An attacker could exploit this to extract, modify, or delete database contents without authorisation.

Attack Technique: Boolean-based SQL Injection using AND '1'='1' and AND '1'='2' conditions.

Remediation: Use PreparedStatements for all database queries, never build SQL queries through string concatenation, validate all user input server-side, and apply least privilege to all database users.

VULNERABILITIES

VULNERABILITY 5b



Name: OWASP ZAP Passive Scan (Path Traversal)
Risk Rating: High

Description: ZAP detected a potential Path Traversal vulnerability. An attacker could manipulate URL inputs using sequences like "../" to navigate outside the intended web directory and access sensitive server files not meant to be publicly accessible.

Attack Technique: URL manipulation using directory traversal sequences and encoded variations like %2e%2e%2f.

Remediation: Validate all file-related input strictly, use allow lists for acceptable filenames, implement path canonicalization, and run all web processes with minimum required privileges.

VULNERABILITIES

VULNERABILITY 5c o

FINDING	RISK	REMEDIATION
Cookie No HttpOnly Flag	Medium	Set HttpOnly attribute on all cookies to prevent JavaScript access
Server Version Information Leak	Medium	Configure server to hide version information from HTTP response headers
X-Content-Type-Options Missing	Medium	Add X-Content-Type-Options: nosniff header to all responses

CONCLUSION & RECOMMENDATIONS

Description: This passive security assessment of Wikipedia.org was conducted ethically using publicly accessible information and industry-standard tools, including Nmap, OWASP ZAP, and Browser DevTools. No exploitation or harmful actions were performed at any stage.

The assessment identified a total of 20 alerts, including two high-risk vulnerabilities, SQL Injection and Path Traversal, which represent the most critical findings requiring immediate remediation. The site demonstrated several strong security practices, including full HTTPS enforcement via HSTS, a valid SSL/TLS certificate, and a minimal network footprint with only ports 80 and 443 exposed.

However, the presence of missing security headers, cookie misconfigurations, server version exposure, and the two high-risk ZAP findings indicate that, despite Wikipedia's overall strong security posture, targeted improvements are needed to fully harden the application against modern web threats.

PRIORITY	FINDING	ACTION
1	SQL Injection	Implement PreparedStatements and input validation immediately
2	Path Traversal	Enforce strict input validation and path canonicalization
3	Missing CSP Header	Define and implement a Content Security Policy
4	Missing X-Frame-Options	Add anti-clickjacking headers
5	Cookie Misconfigurations	Set HttpOnly and SameSite attributes on all cookies
6	Server Version Leak	Hide server version from HTTP response headers
7	SSL Certification Expiry	Enable auto-renewal via Let's Encrypt certbot

CLOSING STATEMENT

Overall, Wikipedia.org maintains a reasonable security baseline for a public-facing platform. With targeted remediation of the identified vulnerabilities, particularly the high-risk findings, the site's security posture can be significantly strengthened. This report serves as a foundation for ongoing security improvement and should be revisited following any major infrastructure or application changes.

WIKIPEDIA

The Free Encyclopedia